

Security+ 5.1 · Security Standards

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.1** — Security Standards (5:36) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Standards are mandatory and specific, such as password standards or access control standards. Guidelines are suggested best practices and are not mandatory. Procedures are step-by-step instructions for performing a task.

High-Yield Core Concepts Tested on Exam

- Standard: mandatory, specific requirements (e.g., password length)
- Guideline: suggested best practice, not mandatory
- Procedure: step-by-step instructions for a task

Exam Tips & Classic Scenarios

- If the question mentions a mandatory document defining how to implement policy, choose standard.
- If it's a suggestion, it's a guideline.

Typical Exam Scenario: A document requires passwords to be at least 14 characters. This is a standard. A suggestion to use a password manager is a guideline.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.1 — Security Standards)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

2. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step...
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'mandatory document defining how to implement policy'=standard'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use manager'=guideline.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use ...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step...

6. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'mandatory document defining how to implement policy'=standard.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use manager'=guideline.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use ...
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step'. What is the best applicable recommendation or control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step...

9. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'mandatory document defining how to implement policy'=standard'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard...

10. Corporate scenario (Security Standards): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'password of at least 14 chars' = standard (mandatory); 'suggestion to use manager' = guideline. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'password of at least 14 chars' = standard (mandatory); 'suggestion to use manager' = guideline
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish:* These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

2) C — Implement the corresponding solution: Standard: MANDATORY; Guideline:

SUGGESTION; Procedure: step-by-step....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step. A standard is a mandatory requirement that must be followed; a guideline is a recommendation or best practice that is not mandatory; a procedure is a detailed, step-by-step instruction for performing a specific task.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'mandatory document defining how to implement policy'=standard. A standard is a mandatory document that specifies how to implement a policy, providing detailed requirements and specifications.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'password of at least 14 chars'=standard (mandatory); 'suggestion to use manager'=guideline. Standards are mandatory requirements, while guidelines are recommendations that provide flexibility.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

6) A — Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'mandatory document defining how to implement policy'=standard. Standards are mandatory documents that specify how policies are to be implemented, providing specific technical or procedural requirements.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: 'password of at least 14 chars'=standard (mandatory); 'suggestion to use

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'password of at least 14 chars'=standard (mandatory); 'suggestion to use manager'=guideline. This distinction is crucial: standards are mandatory requirements that must be followed, while guidelines are recommendations that are not mandatory. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): Standard: MANDATORY; Guideline: SUGGESTION; Procedure: step-by-step. This accurately defines the hierarchy and enforceability of security documentation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'mandatory document defining how to implement policy'=standard....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'mandatory document defining how to implement policy'=standard. A standard is a mandatory, detailed document that specifies how policies are implemented, often referencing specific technologies, configurations, or procedures.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'password of at least 14 chars' = standard (mandatory); 'suggestion to use manager' = guideline.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Standards): 'password of at least 14 chars' = standard (mandatory); 'suggestion to use manager' = guideline. Standards are mandatory requirements, while guidelines are recommendations, reflecting different levels of enforcement.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

